

# KO Assets API Security Review Documentation

This document provides comprehensive API documentation for security assessment of the KO Assets platform.

## Table of Contents

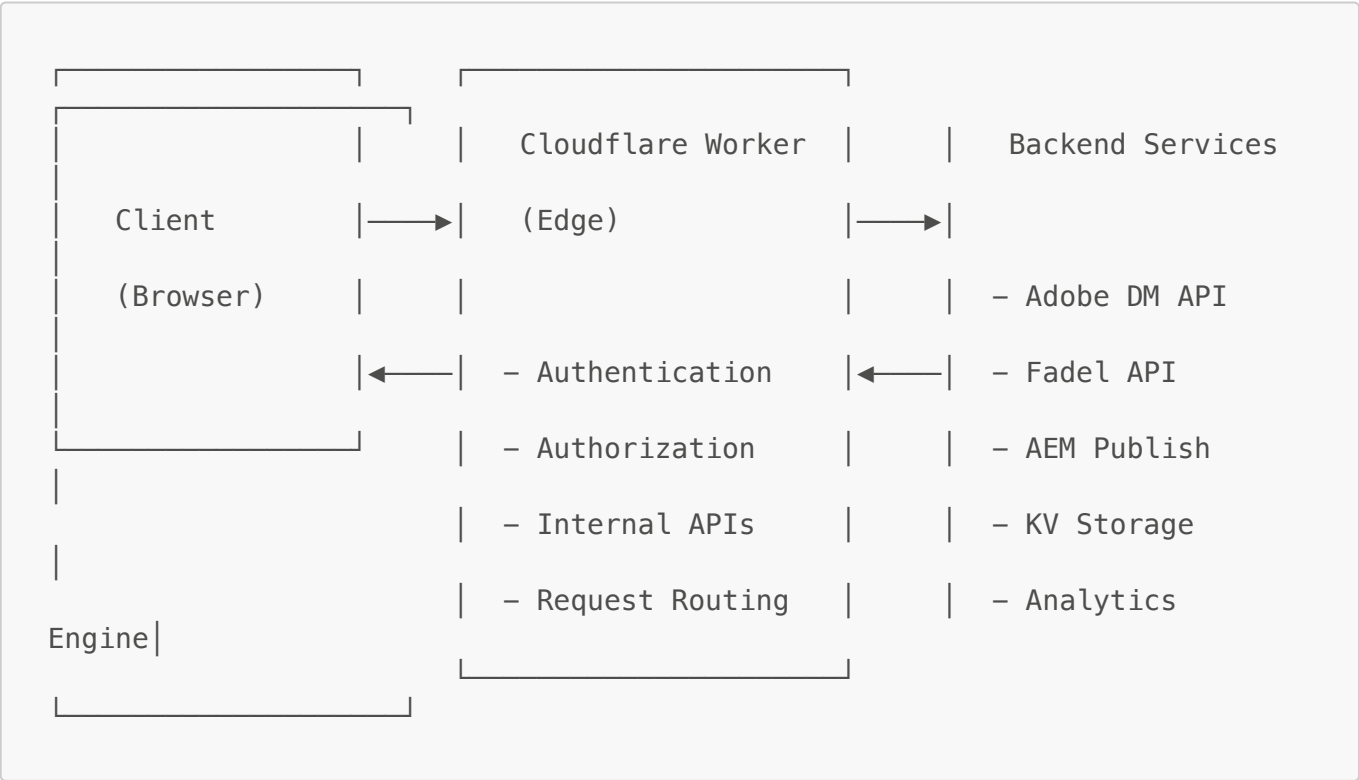
- 1. [Overview](#)
- 2. [Authentication](#)
- 3. [API Categories](#)
- 4. [Internal APIs](#)
- 5. [Proxied APIs](#)
- 6. [Security Considerations](#)
- 7. [Testing Resources](#)

## Overview

KO Assets is a digital asset management platform built on:

- **Cloudflare Workers:** Edge computing for API routing, authentication, and business logic
- **Adobe Experience Manager (AEM):** Content delivery via Helix/EDS
- **Adobe Dynamic Media:** Asset storage and delivery
- **Cloudflare KV:** Distributed key-value storage for user data
- **Cloudflare Analytics Engine:** Event tracking and reporting

## Architecture



Base URLs

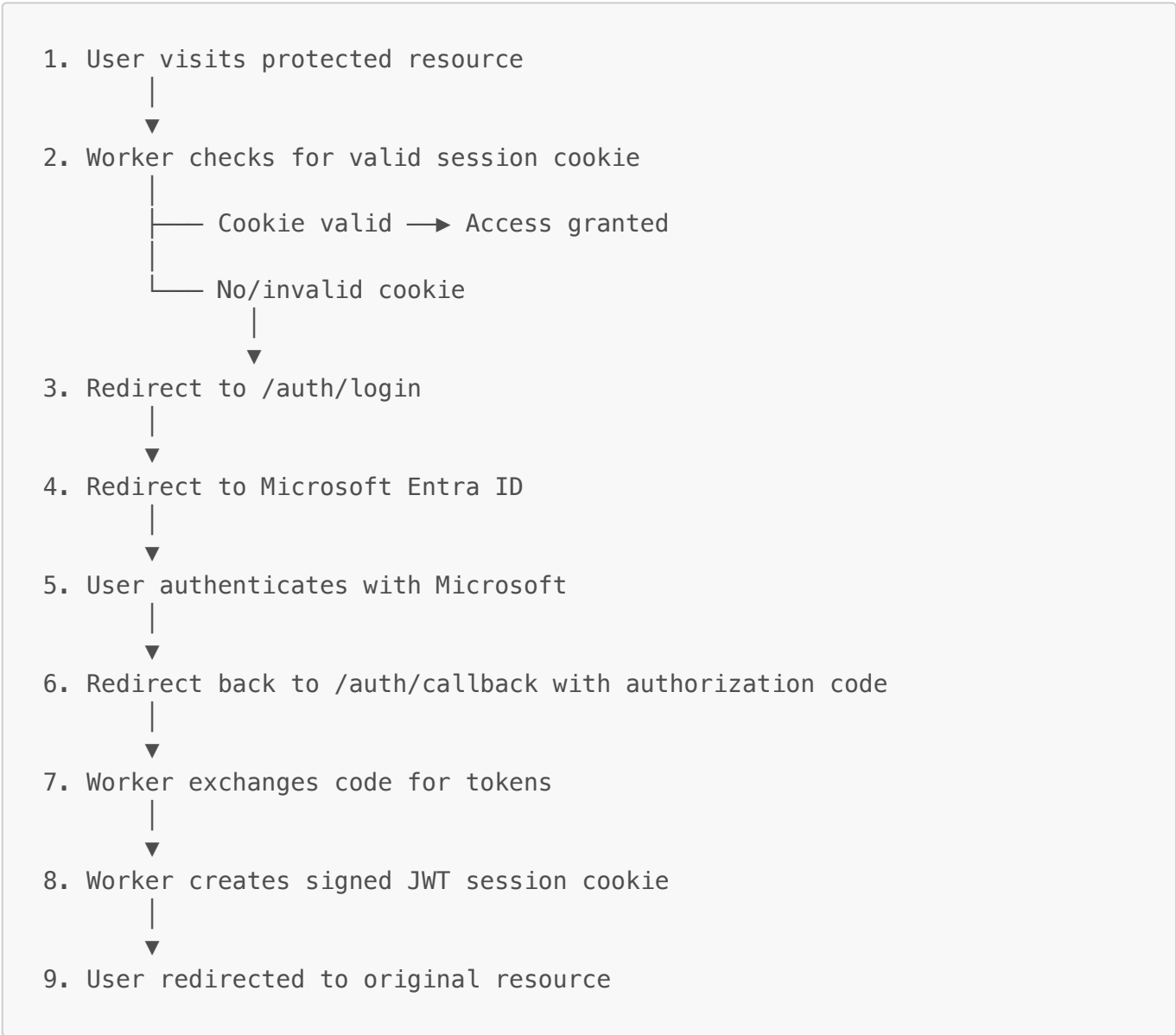
| Environment       | URL                                                                                                                   |
|-------------------|-----------------------------------------------------------------------------------------------------------------------|
| Production        | <a href="https://koassets.adobeaem.workers.dev">https://koassets.adobeaem.workers.dev</a>                             |
| Preview           | <a href="https://preview-koassets.adobeaem.workers.dev">https://preview-koassets.adobeaem.workers.dev</a>             |
| Branch (preview)  | <a href="https://{branch}-koassets.adobeaem.workers.dev">https://{branch}-koassets.adobeaem.workers.dev</a>           |
| Branch (live)     | <a href="https://{branch}-live-koassets.adobeaem.workers.dev">https://{branch}-live-koassets.adobeaem.workers.dev</a> |
| Local Development | <a href="http://localhost:8787">http://localhost:8787</a>                                                             |

Authentication

OAuth/OIDC Flow

KO Assets uses **Microsoft Entra ID** (formerly Azure AD) for authentication via OAuth 2.0 / OpenID Connect.

Authentication Flow



Session Cookie

| Attribute  | Value                           |
|------------|---------------------------------|
| Name       | session                         |
| Type       | Signed JWT                      |
| Expiration | Configurable (default: 6 hours) |
| Secure     | Yes (HTTPS only)                |
| HttpOnly   | Yes                             |
| SameSite   | Lax                             |

Session Payload (JWT Claims)

```
{
  "sub": "microsoft-entra-user-id",
  "name": "John Doe",
  "email": "john.doe@coca-cola.com",
  "country": "US",
  "employeeType": "10",
  "koid": "12345",
  "company": "The Coca-Cola Company",
  "permissions": ["preview", "admin-reports"],
  "roles": ["employee"],
  "countries": [],
  "customers": [],
  "brands": [],
  "exp": 1704931200,
  "iat": 1704909600
}
```

Authorization Model

Permissions

Configured in /config/access/permissions (AEM EDS sheet):

| Permission    | Description                                      |
|---------------|--------------------------------------------------|
| preview       | Access to preview/branch environments            |
| sudo          | User impersonation for testing                   |
| admin-reports | Access to admin reports and analytics            |
| admin-rights  | Full rights review management (assign to others) |
| manage-rights | Rights review access (self-assign only)          |

Roles

Configured in `/config/access/companies` and `/config/access/users`:

| Role                           | Description                               |
|--------------------------------|-------------------------------------------|
| <code>admin</code>             | Full access to all content                |
| <code>employee</code>          | TCCC employee (employeeType: 10)          |
| <code>contingent-worker</code> | TCCC contingent worker (employeeType: 11) |
| <code>agency</code>            | External agency partner                   |
| <code>bottler</code>           | Bottling partner (country-restricted)     |

Impersonation (Sudo)

Users with `sudo` permission can impersonate other users via cookies:

| Cookie                          | Purpose                                |
|---------------------------------|----------------------------------------|
| <code>SUDO_NAME</code>          | Override display name                  |
| <code>SUDO_EMAIL</code>         | Override email (changes authorization) |
| <code>SUDO_COUNTRY</code>       | Override country                       |
| <code>SUDO_EMPLOYEE_TYPE</code> | Override employee type                 |

API Categories

Internal APIs (Cloudflare Worker)

These APIs are implemented directly in the Cloudflare Worker:

| Category        | Path Prefix                        | Storage          |
|-----------------|------------------------------------|------------------|
| User            | <code>/api/user</code>             | Session cookie   |
| Saved Searches  | <code>/api/savedsearches/*</code>  | Cloudflare KV    |
| Rights Requests | <code>/api/rightsrequests/*</code> | Cloudflare KV    |
| Notifications   | <code>/api/messages/*</code>       | Cloudflare KV    |
| Analytics       | <code>/api/analytics/*</code>      | Analytics Engine |

Proxied APIs (External Services)

These APIs are proxied to external services with authentication handled by the Worker:

| Category      | Path Prefix                      | Backend                                |
|---------------|----------------------------------|----------------------------------------|
| Dynamic Media | <code>/api/adobe/assets/*</code> | <code>delivery-*.adobecloud.com</code> |

| Category    | Path Prefix    | Backend                     |
|-------------|----------------|-----------------------------|
| Fadel       | /api/fadel/*   | *.fadelarc.net              |
| AEM Publish | /api/publish/* | publish-*.adobeaemcloud.com |

## Internal APIs

### 1. User API

| Endpoint  | Method | Auth     | Permission | Description           |
|-----------|--------|----------|------------|-----------------------|
| /api/user | GET    | Required | Any        | Get current user info |

#### GET /api/user

Returns the authenticated user's profile and permissions.

#### Response (200 OK):

```
{
  "name": "John Doe",
  "email": "john.doe@coca-cola.com",
  "country": "US",
  "employeeType": "10",
  "koid": "12345",
  "company": "The Coca-Cola Company",
  "permissions": ["preview", "admin-reports"],
  "roles": ["employee"],
  "countries": [],
  "customers": [],
  "brands": [],
  "sessionExpiresInSec": 21600
}
```

### 2. Saved Searches API

All keys are automatically scoped to the authenticated user.

| Endpoint                  | Method | Auth     | Permission | Description               |
|---------------------------|--------|----------|------------|---------------------------|
| /api/savedsearches/list   | GET    | Required | Any        | List saved search keys    |
| /api/savedsearches/get    | GET    | Required | Any        | Get user's saved searches |
| /api/savedsearches/set    | POST   | Required | Any        | Save searches             |
| /api/savedsearches/delete | POST   | Required | Any        | Delete saved searches     |

| Endpoint                          | Method | Auth     | Permission    | Description          |
|-----------------------------------|--------|----------|---------------|----------------------|
| /api/savedsearches/report-metrics | GET    | Required | admin-reports | Admin report metrics |

POST /api/savedsearches/set

Request Body:

```
{
  "value": [
    {
      "id": "search-123",
      "name": "Coca-Cola Red Assets",
      "searchTerm": "coca-cola red",
      "filters": {"brand": "Coca-Cola"},
      "dateCreated": "2024-01-15T10:30:00Z"
    }
  ],
  "metadata": {"version": 1},
  "expirationTtl": null
}
```

Response (200 OK):

```
{
  "success": true,
  "key": "user:john.doe@coca-cola.com:saved-searches",
  "message": "Value set successfully"
}
```

3. Rights Requests API

| Endpoint                   | Method | Auth     | Permission    | Description          |
|----------------------------|--------|----------|---------------|----------------------|
| /api/rightsrequests        | GET    | Required | Any           | List user's requests |
| /api/rightsrequests        | POST   | Required | Any           | Create new request   |
| /api/rightsrequests/status | POST   | Required | Any (own)     | Cancel own request   |
| /api/rightsrequests/all    | GET    | Required | admin-reports | List all requests    |

| Endpoint                              | Method | Auth     | Permission     | Description    |
|---------------------------------------|--------|----------|----------------|----------------|
| /api/rightsrequests/reviews           | GET    | Required | manage-rights  | List reviews   |
| /api/rightsrequests/reviews/reviewers | GET    | Required | admin-rights   | List reviewers |
| /api/rightsrequests/reviews/assign    | POST   | Required | manage-rights* | Assign review  |
| /api/rightsrequests/reviews/status    | POST   | Required | manage-rights  | Update status  |

\*Self-assignment requires `manage-rights`; assigning to others requires `admin-rights`

Request Statuses

| Status          | Set By    | Description                |
|-----------------|-----------|----------------------------|
| Not Started     | System    | Initial state              |
| In Progress     | Reviewer  | Review has begun           |
| RM Canceled     | Reviewer  | Canceled by rights manager |
| Quote Pending   | Reviewer  | Awaiting quote             |
| Release Pending | Reviewer  | Awaiting release           |
| Done            | Reviewer  | Review complete            |
| User Canceled   | Submitter | Canceled by requester      |

POST /api/rightsrequests

Request Body:

```
{
  "restrictedAssets": [
    {"assetId": "urn:aaid:aem:abc123", "name": "Campaign Asset.jpg"}
  ],
  "agencyType": "Associate",
  "agencyName": "TCCC Marketing",
  "contactName": "John Doe",
  "contactEmail": "john.doe@coca-cola.com",
  "contactPhone": "+1-555-0123",
  "airDate": "2024-03-01",
  "pullDate": "2024-06-01",
  "selectedMarkets": [{"id": 1, "name": "North America"}],
  "selectedMediaChannels": [{"id": 1, "name": "Digital"}],
  "materialsRequiredDate": "2024-02-15",
  "formatsRequired": "PSD, JPEG",
}
```

```
"usageRightsRequired": {"music": true, "talent": false},
"adaptationIntention": "None",
"budgetForMarket": "$50,000",
"exceptionOrNotes": "Urgent request"
}
```

#### 4. Notifications API

| Endpoint          | Method | Auth     | Permission | Description         |
|-------------------|--------|----------|------------|---------------------|
| /api/messages     | GET    | Required | Any        | List notifications  |
| /api/messages     | POST   | Required | Any        | Create notification |
| /api/messages/:id | GET    | Required | Any (own)  | Get notification    |
| /api/messages/:id | POST   | Required | Any (own)  | Update notification |
| /api/messages/:id | DELETE | Required | Any (own)  | Delete notification |

##### POST /api/messages

##### Request Body:

```
{
  "id": "notif-456",
  "subject": "New Asset Available",
  "message": "A new asset matching your saved search is now available.",
  "type": "Notification",
  "from": "system@coca-cola.com",
  "priority": "normal",
  "expiresInXDays": 30,
  "status": "unread"
}
```

#### 5. Analytics API

| Endpoint                      | Method | Auth     | Permission    | Description       |
|-------------------------------|--------|----------|---------------|-------------------|
| /api/analytics                | POST   | Required | Any           | Track event       |
| /api/analytics/report-metrics | GET    | Required | admin-reports | Report metrics    |
| /api/analytics/query          | POST   | Required | admin-reports | SQL query         |
| /api/analytics/raw-downloads  | GET    | Required | admin-reports | Raw download data |

##### Event Types



**Login Event:**

```
{
  "eventType": "login",
  "koid": "12345",
  "country": "US",
  "employeeType": "10",
  "company": "The Coca-Cola Company",
  "roles": ["employee"]
}
```

**Search Event:**

```
{
  "eventType": "search",
  "koid": "12345",
  "country": "US",
  "employeeType": "10",
  "company": "The Coca-Cola Company",
  "roles": ["employee"],
  "searchTerm": "coca-cola summer campaign",
  "resultCount": 42
}
```

**Download Event:**

```
{
  "eventType": "download",
  "koid": "12345",
  "country": "US",
  "employeeType": "10",
  "company": "The Coca-Cola Company",
  "roles": ["employee"],
  "resourceType": "asset",
  "brand": "Coca-Cola",
  "campaigns": "Summer 2024",
  "downloadId": "dl-abc123",
  "downloadItemId": "urn:aaid:aem:asset123",
  "downloadType": "ready-to-use",
  "rendition": "original"
}
```

**Valid downloadType values:** ready-to-use, restricted, unknown

---

## Proxied APIs

## 6. Dynamic Media API

Proxied to Adobe Dynamic Media OpenAPI ([delivery-\\*.adobecloud.com](#)).

| Endpoint                                               | Method | Description        |
|--------------------------------------------------------|--------|--------------------|
| <a href="#">/api/adobe/assets/search</a>               | POST   | Search assets      |
| <a href="#">/api/adobe/assets/search-collections</a>   | POST   | Search collections |
| <a href="#">/api/adobe/assets/:id</a>                  | GET    | Get asset metadata |
| <a href="#">/api/adobe/assets/:id/as/thumbnail.jpg</a> | GET    | Get thumbnail      |
| <a href="#">/api/adobe/assets/:id/as/:rendition</a>    | GET    | Get rendition      |
| <a href="#">/api/adobe/assets/archive/create</a>       | POST   | Create ZIP archive |

### POST [/api/adobe/assets/search](#)

**Request Body:**

```
{
  "query": {"text": "coca-cola summer"},
  "filters": {"dc:format": ["image/jpeg", "image/png"]},
  "limit": 20,
  "offset": 0
}
```

### Archive Download (x-analytics-context Header)

For multi-asset downloads, analytics context is passed via header:

```
x-analytics-context: {
  "downloadId": "dl-123",
  "assets": [
    {
      "assetId": "urn:aaid:aem:abc123",
      "brand": "Coca-Cola",
      "campaign": "Summer",
      "downloadType": "ready-to-use",
      "renditions": ["original"]
    }
  ]
}
```

---

## 7. Fadel API

Proxied to Fadel rights management system ([\\*.fadelarc.net](#)).

| Endpoint                   | Method | Description        |
|----------------------------|--------|--------------------|
| /api/fadel/rights/check    | POST   | Check asset rights |
| /api/fadel/rights/:assetId | GET    | Get rights details |

8. AEM Publish API

Proxied to AEM CS Publish environment ([publish-\\*.adobeaemcloud.com](#)).

| Endpoint       | Method   | Description        |
|----------------|----------|--------------------|
| /api/publish/* | GET/POST | Access AEM content |

Security Considerations

Authentication & Sessions

| Consideration      | Implementation                                     |
|--------------------|----------------------------------------------------|
| Session security   | JWT signed with secret, HttpOnly, Secure, SameSite |
| Session expiration | Configurable (default 6h), enforced server-side    |
| Token storage      | Session cookie only, no localStorage               |
| CORS               | Restricted to allowed origins                      |

Authorization

| Consideration    | Implementation                                    |
|------------------|---------------------------------------------------|
| Permission model | Role-based + resource-based (per-user overrides)  |
| Data isolation   | KV keys scoped to user email                      |
| Admin functions  | Explicit permission checks                        |
| Impersonation    | Requires explicit <a href="#">sudo</a> permission |

API Security

| Consideration    | Implementation                                |
|------------------|-----------------------------------------------|
| Rate limiting    | Cloudflare built-in                           |
| Input validation | Server-side validation for all inputs         |
| SQL injection    | Analytics Engine uses parameterized queries   |
| XSS              | No user content rendered without sanitization |

Data Privacy

| Consideration  | Implementation                                   |
|----------------|--------------------------------------------------|
| PII handling   | Email stored in session, koid used for analytics |
| Audit logging  | Events tracked in Analytics Engine               |
| Data retention | KV data with optional TTL                        |

Proxy Security

| Consideration     | Implementation                        |
|-------------------|---------------------------------------|
| Backend auth      | Separate service accounts per backend |
| Request filtering | Headers sanitized before proxying     |
| Response handling | Error responses normalized            |

## Testing Resources

Postman Collection

Import `koassets-api-collection-postman.json` into Postman:

1. Open Postman
2. Click Import → Upload Files
3. Select `koassets-api-collection-postman.json`
4. Set collection variables:
  - `baseUrl`: Your target environment URL
  - `sessionCookie`: Your session cookie value

curl Examples

See `koassets-api-collection-curl.sh` for executable examples:

```
# Set environment variables
export BASE_URL="https://koassets.adobeam.workers.dev"
export SESSION_COOKIE="your_session_cookie_value"

# Source the file for helper functions
source koassets-api-collection-curl.sh

# Or run individual commands from the file
```

Obtaining a Session Cookie

1. Navigate to the application in a browser
2. Complete Microsoft Entra ID authentication
3. Open Developer Tools → Network tab
4. Copy the `session` cookie value from the request headers

---

## Error Responses

All APIs return consistent error responses:

### 401 Unauthorized:

```
{
  "error": "Unauthorized"
}
```

### 403 Forbidden:

```
{
  "success": false,
  "error": "admin-reports permission required",
  "message": "You do not have permission to access this resource"
}
```

### 404 Not Found:

```
{
  "success": false,
  "error": "Resource not found"
}
```

### 500 Internal Server Error:

```
{
  "success": false,
  "error": "Internal server error",
  "message": "Error details..."
}
```

---

## Contact

For questions about this security review documentation, contact the KO Assets development team.